

TP Autonomie

1. Malwares

Powershell

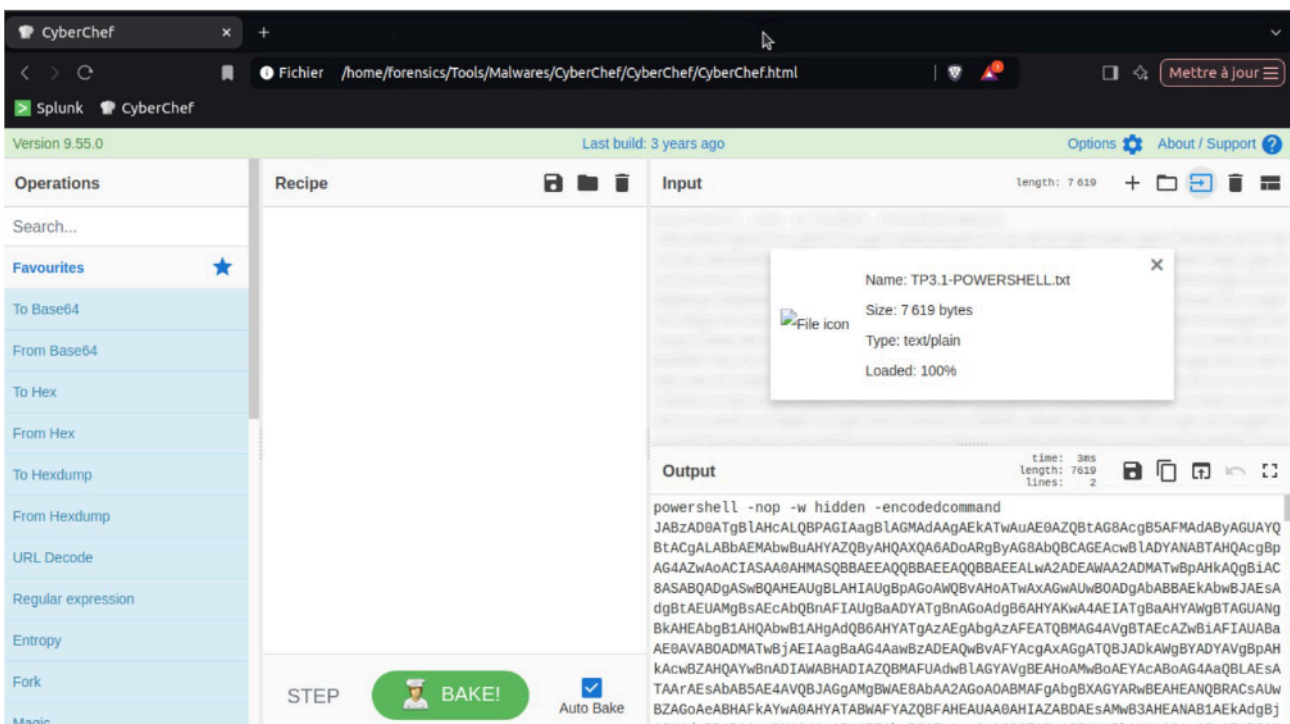
Nous allons investiguer la fonction powershell que vous trouverez dans le fichier suivant:

/home/forensics/Bureau/Cases/5_MALWARES/TP/TP3.1-POWERSHELL/TP3.1-POWERSHELL.txt

```
$ root@forensics-vm /h/f/C/S/T/TP3.1-POWERSHELL bash
root@forensics-vm:/home/forensics/Bureau/Cases/5_MALWARES/TP/TP3.1-POWERSHELL#
root@forensics-vm:/home/forensics/Bureau/Cases/5_MALWARES/TP/TP3.1-POWERSHELL#
root@forensics-vm:/home/forensics/Bureau/Cases/5_MALWARES/TP/TP3.1-POWERSHELL#
root@forensics-vm:/home/forensics/Bureau/Cases/5_MALWARES/TP/TP3.1-POWERSHELL# ls -l
total 8
-rw-rw-r-- 1 forensics forensics 7619 mai  7 2022 TP3.1-POWERSHELL.txt
root@forensics-vm:/home/forensics/Bureau/Cases/5_MALWARES/TP/TP3.1-POWERSHELL#
```

Vous pouvez suivre les étapes suivantes:

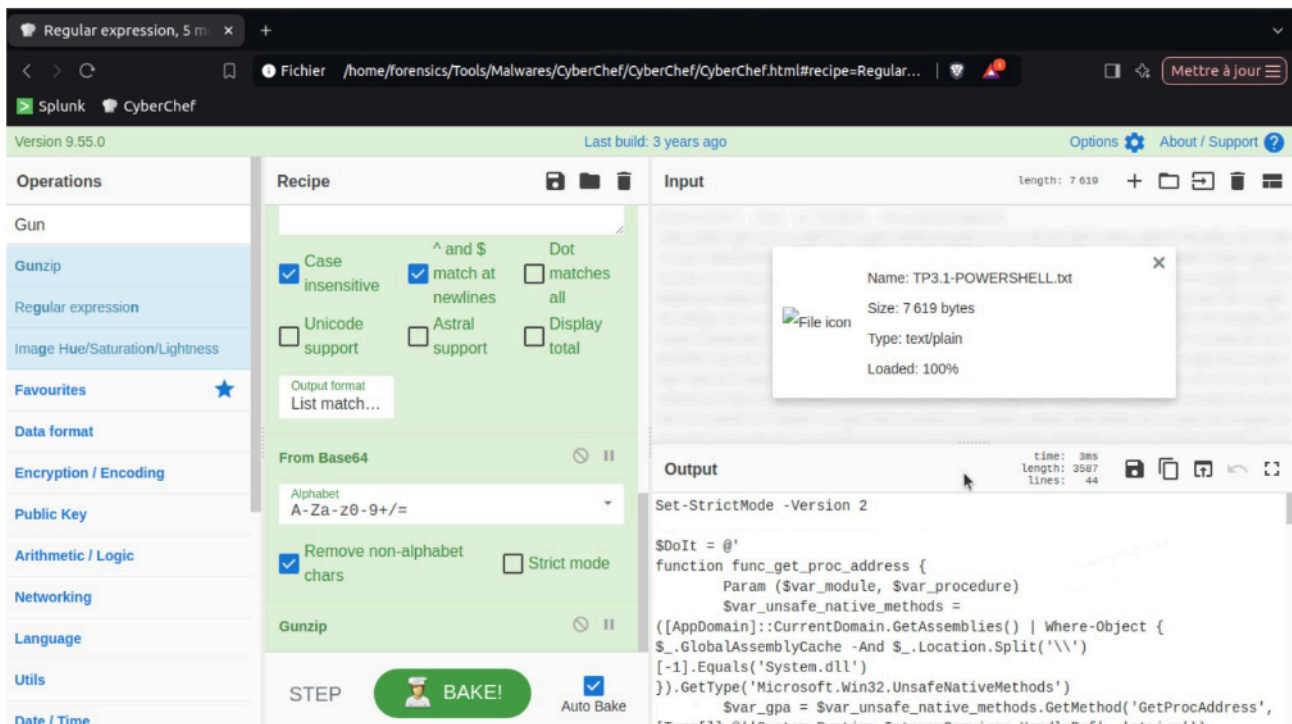
1. Lancer le navigateur Brave et ouvrir CyberChef
2. Insérer le fichier dans la partie Input



3. Rajouter les blocs suivant dans l'ordre dans le Recipe:

1. Regular expression: [A-Za-z0-9+/=]{30,} avec le format de sortie "List matches"
2. From Base64: A-Za-z0-9+/=
3. Decode text avec un encodage "UTF-16LE (1200)"
4. Regular expression: [A-Za-z0-9+/=]{30,} avec le format de sortie "List matches"
5. From Base64: A-Za-z0-9+/=
6. Gunzip

Nous obtenons la suite :



4. Essayez de comprendre l'intérêt de chacun des bloc et ce qu'on peut conclure de cette procédure.

La première regex cherche une suite d'au moins 30 caractères d'affilée composés uniquement de lettres (majuscules/minuscules), de chiffres, de +, de / ou de =. Le but est d'isoler et extraire uniquement le gros bloc qui ressemble à du Base64 et ignorer tout le reste du fichier.

On décode ensuite ce qu'on a obtenu en base 64 puis on le traduit avec un encodage UTF16 LE.

On refait ensuite ces mêmes étapes pour finir avec une décompression des données avec gunzip.

Le code qu'on obtient se découpe en 4 parties :

Voici le résumé flash en 4 étapes :

- 1. Le ciblage (32-bit) : Le script vérifie le système et force l'exécution en mode 32-bit si nécessaire pour que son code secret fonctionne.
- 2. L'esquive (Réflexion) : Il utilise une technique de "réflexion" pour appeler discrètement des fonctions de Windows sans se faire repérer par les radars de l'antivirus.
- 3. Le déballage (XOR 35) : Il prend le gros bloc de texte mystère, le décode, et applique une clé magique (une opération XOR avec le nombre 35) pour révéler le vrai code malveillant caché.
- 4. L'injection : Il réserve un espace secret dans la RAM, y copie le code déchiffré et l'exécute immédiatement.

Pdf

Dans le répertoire /home/forensics/Cases/5_MALWARES/TP/TP3.0-PDF/ vous avez deux fichiers PDF, analysez les avec /home/forensics/Tools/Malwares/Pdf/Pdf_parser.sh (voir les options disponibles dans l'aide).

PDF parser est un utilitaire permettant d'analyser des fichiers PDF. Il permet de voir et d'extraire des données brutes présentes dans le fichier.

On peut voir tous les blocs présent dans le fichier avec l'option -a et on peut spécifier un bloc avec l'option -o.

Dans ce fichier, on peut voir dans le premier objet une commande /OpenAction 7 0 R :

```
obj 1 0
Type: /Catalog
Referencing: 2 0 R, 3 0 R, 7 0 R

<<
  /Type /Catalog
  /Outlines 2 0 R
  /Pages 3 0 R
  /OpenAction 7 0 R
>>
```

Cette commande va donc exécuter le bloc 7 0 et le R va forcer l'exécution de l'action.

Quand on regarde le bloc 7 , on trouve le code suivant :

```
obj 7 0
  Type: /Action
  Referencing:

  <<
    /Type /Action
    /S /JavaScript
    /JS (this.getURL("http://www.google.fr", false);)
  >>
```

Lorsque le fichier sera ouvert, il va donc émettre une requête vers google.fr.

Dans le premier bloc du second fichier, on peut voir qu'un fichier nommé eicar-dropper.doc est intégré dans le PDF :

```
obj 1 0
  Type: /Catalog
  Referencing: 2 0 R, 3 0 R, 7 0 R, 9 0 R

  <<
    /Type /Catalog
    /Outlines 2 0 R
    /Pages 3 0 R
    /Names
      <<
        /EmbeddedFiles
          <<
            /Names [(eicar-dropper.doc) 7 0 R]
          >>
        >>
      >>
    /OpenAction 9 0 R
  >>
```

De plus, le bloc 9 0 sera exécuté lors de l'ouverture du PDF. Dans ce bloc 9 0, on trouve ceci :

```
obj 9 0
  Type: /Action
  Referencing:

  <<
    /Type /Action
    /S /JavaScript
    /JS (this.exportDataObject({ cName: "eicar-dropper.doc", nLaunch: 2 }));)
  >>
```

Le fichier cité plus haut sera extrait du PDF puis lancé immédiatement (nLaunch : 2)

Quand on ajoute les option -f et -w à la commande, nous obtenons le contenu du fichier en brut mais nous avons tout de même des informations intéressantes :

[illegible]

Nous pouvons notamment voir que c'est bien un fichier doc grâce à la signature du fichier.

2. Mémoire

Pendant les vacances, un analyste de l'entreprise JMCorp a laissé son ordinateur non verrouillé dans sa chambre pendant une pause cigarette. Quand il est revenu dans sa chambre un homme masqué est sur son ordinateur. Après avoir essayé de le stopper, l'homme masqué le frappa et partit. Juste après les évènements, selon les procédures en vigueur au sein de JMCorp, un dump de la mémoire de l'ordinateur "tel quel" a été réalisé et vous a été envoyé. Le disque, trop volumineux, ne vous parviendra que plus tard.

Dans le répertoire /home/forensics/Cases/2_MEM/TP vous trouverez le fichier TP1-v2-Mem.7z. Décompresser et analyser ce fichier avec volatility 2. Commencer par afficher la version de l'OS. Durant la SAE, vous aurez à analyser ce dump mémoire afin de déterminer un enchainement chronologique sur l'attaque réalisée. N'oubliez pas de suivre les recommandations vues sans le cours pour la rédaction du rapport d'investigation forensics. Voici les questions que l'investigateur souhaite connaître (en plus de tout autre information découverte durant l'analyse):

Le fichier est bien présent :

```
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# ls -l
total 370816
-rw-rw-r-- 1 forensics forensics 327539777 janv. 26  2023 TP1-v2-Mem.7z
-rwxr-xr-x 1 forensics forensics  52168925 juin  10  2017 TP2-Mem.raw.7z
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP#
```

Il faut Dé-7zip le tout :

```

root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# 7z x TP1-v2-Mem.7z

7-Zip [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (locale=fr_FR.UTF-8,Utf16=on,HugeFiles=on,64 bits,2 CPUs Common KVM processor (F61),ASM)

Scanning the drive for archives:
1 file, 327539777 bytes (313 MiB)

Extracting archive: TP1-v2-Mem.7z
--
Path = TP1-v2-Mem.7z
Type = 7z
Physical Size = 327539777
Headers Size = 138
Method = LZMA2:24
Solid = -
Blocks = 1

Everything is Ok

Size:          2147483648
Compressed: 327539777
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP#

```

- Quel est le nom de la machine ?

Tout d'abord, imageinfo pour avoir le profil de la machine :

```

root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw imageinfo
Volatility Foundation Volatility Framework 2.6
INFO : volatility.debug : Determining profile based on KDBG search...
Suggested Profile(s) : Win7SP1x64, Win7SP0x64, Win2008R2SP0x64, Win2008R2SP1x64_23418, Win2008R2SP1x64, Win7SP1x64_23418
AS Layer1 : WindowsAMD64PagedMemory (Kernel AS)
AS Layer2 : FileAddressSpace (/home/forensics/Cases/2_MEM/TP/TP1-v2-Mem.raw)
PAE type : No PAE
DTB : 0x187000L
KDBG : 0xf80002a3a120L
Number of Processors : 1
Image Type (Service Pack) : 1
KPCR for CPU 0 : 0xfffff80002a3c000L
KUSER_SHARED_DATA : 0xfffff78000000000L
Image date and time : 2018-05-12 11:12:17 UTC+0000
Image local date and time : 2018-05-12 13:12:17 +0200

```

On fait envvars et on recherche la clé COMPUTERTNAME :

```

root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 envvars | grep -l "COMPUTERTNAME"
Volatility Foundation Volatility Framework 2.6
460 wininit.exe 0x0000000000408b60 COMPUTERTNAME JMCOMPUTER

```

On trouve alors que le PC s'appelle JMCOMPUTER (surement un coup de Jean-Michel)

- Quelle version de Microsoft Windows est utilisée ?

D'après l'image info, nous avons une Windows 7 :

```

root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw imageinfo
Volatility Foundation Volatility Framework 2.6
INFO : volatility.debug : Determining profile based on KDBG search...
Suggested Profile(s) : Win7SP1x64, Win7SP0x64, Win2008R2SP0x64, Win2008R2SP1x64_23418, Win2008R2SP1x64, Win7SP1x64_23418
AS Layer1 : WindowsAMD64PagedMemory (Kernel AS)
AS Layer2 : FileAddressSpace (/home/forensics/Cases/2_MEM/TP/TP1-v2-Mem.raw)
PAE type : No PAE
DTB : 0x187000L
KDBG : 0xf80002a3a120L
Number of Processors : 1
Image Type (Service Pack) : 1
KPCR for CPU 0 : 0xfffff80002a3c000L
KUSER_SHARED_DATA : 0xfffff78000000000L
Image date and time : 2018-05-12 11:12:17 UTC+0000
Image local date and time : 2018-05-12 13:12:17 +0200
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP#

```

- Quel utilisateur était connecté à la machine ?

Pour voir l'utilisateur connecté à la machine, nous devons réaliser la commande suivante :

```
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 envvars | grep -i "USERNAME"
Volatility Foundation Volatility Framework 2.6
```

On trouve alors 3 utilisateurs :

- SYSTEM → c'est le système
- JMCOMPUTER → compte de la machine
- boulet → compte de l'utilisateur

- Quel est le mot de passe de l'utilisateur de la machine ?

Pour ce faire, nous faisons un hashdump :

```
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 hashdump
Volatility Foundation Volatility Framework 2.6
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invt:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HomeGroupUser$:1002:aad3b435b51404eeaad3b435b51404ee:0e4a8ec68b0ceddb9dde8aaf86bdad9b:::
boulet:1003:aad3b435b51404eeaad3b435b51404ee:4bbeea2f2f758e01a444a0fdf1bb6c6b:::
administartor:1004:aad3b435b51404eeaad3b435b51404ee:eca2bda1eab01a10acc042aca08865bf:::
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP#
```

Nous trouvons le hash NTLM de l'utilisateur boulet que nous mettons dans un décodeur :

Nous trouvons donc que son mot de passe, et bien c'est « boulet » xD.

Nous faisons pareil pour le compte administartor et trouvons un aberrant mot de passe :

Ntlm Encrypt & Decrypt

eca2bda1eab01a10acc042aca08865bf

eca2bda1eab01a10acc042aca08865bf : iambad

Encrypt

Decrypt

- Un processus semble avoir un comportement anormal, lequel ? Où se situe-t-il sur la machine ?

Pour ce faire, nous passons par l'applet pstree :

```
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 pstree
Volatility Foundation Volatility Framework 2.6
Name                               Pid  PPid  Thds  Hnds  Time
-----
0xfffffa8003b01060:csrss.exe        420   408    10    552  2018-05-12 10:59:33 UTC+0000
.. 0xfffffa8001ec6b00:conhost.exe    2876  420     1     32  2018-05-12 11:12:17 UTC+0000
0xfffffa8002f8c060:wininit.exe      460   408     3     76  2018-05-12 10:59:33 UTC+0000
.. 0xfffffa8003d2c8e0:lsmd.exe        556   460    10    205  2018-05-12 10:59:34 UTC+0000
.. 0xfffffa8003c10b00:services.exe    536   460     9    221  2018-05-12 10:59:34 UTC+0000
.. 0xfffffa8003f75b00:spoolsv.exe    1152  536    13    279  2018-05-12 10:59:35 UTC+0000
.. 0xfffffa8003da7b00:SearchIndexer.  2772  536    13    652  2018-05-12 10:59:49 UTC+0000
.. 0xfffffa8003ea9410:svchost.exe     904   536    21    515  2018-05-12 10:59:34 UTC+0000
... 0xfffffa8002091b00:WUDFHost.exe   3232  904     9    213  2018-05-12 11:10:49 UTC+0000
... 0xfffffa800443bb00:dwm.exe         2472  904     3     74  2018-05-12 10:59:43 UTC+0000
.. 0xfffffa80040875f0:svchost.exe    1292  536    11    336  2018-05-12 10:59:35 UTC+0000
.. 0xfffffa8001995760:VGAuthService.  1428  536     4     97  2018-05-12 10:59:35 UTC+0000
.. 0xfffffa800443cb00:taskhost.exe    2200  536    11    240  2018-05-12 10:59:40 UTC+0000
.. 0xfffffa8001c4d370:TrustedInstall  1692  536     4    124  2018-05-12 11:02:34 UTC+0000
.. 0xfffffa8002340b00:msdtc.exe       1696  536    13    147  2018-05-12 10:59:37 UTC+0000
.. 0xfffffa8004ca6b00:svchost.exe     424   536     6    122  2018-05-12 10:59:35 UTC+0000
.. 0xfffffa8003e0b310:svchost.exe     684   536    10    368  2018-05-12 10:59:34 UTC+0000
... 0xfffffa80035adb00:WmiPrvSE.exe    2008  684    10    204  2018-05-12 10:59:36 UTC+0000
... 0xfffffa80023435f0:WmiPrvSE.exe    2948  684    12    251  2018-05-12 10:59:56 UTC+0000
... 0xfffffa8001aa2b00:dlldhost.exe    3608  684     4    120  2018-05-12 11:09:44 UTC+0000
.. 0xfffffa8001aad8a0:svchost.exe    3632  536    10    123  2018-05-12 11:01:36 UTC+0000
.. 0xfffffa8004198060:vmtoolsd.exe    1460  536     9    310  2018-05-12 10:59:35 UTC+0000
... 0xfffffa8001c1db00:cmd.exe         3940  1460     0  -----  2018-05-12 11:12:17 UTC+0000
... 0xfffffa80040d4580:ipconfig.exe    204   3940     0  -----  2018-05-12 11:12:17 UTC+0000
.. 0xfffffa800433eb00:dlldhost.exe    1092  536    14    189  2018-05-12 10:59:36 UTC+0000
.. 0xfffffa8001afc060:svchost.exe     968   536    16    401  2018-05-12 11:01:36 UTC+0000
.. 0xfffffa8003f623f0:svchost.exe    1036  536    24    678  2018-05-12 10:59:35 UTC+0000
```

A la fin, nous trouvons un programme anormal avec smss :


```

.. 0xfffffa8004a88380:firefox.exe          3192    3048    21    286 2018-05-12 11:05:04 UTC+0000
0xfffffa800184eb00:System                4      0    103   480 2018-05-12 10:59:32 UTC+0000
. 0xfffffa800346d610:ssms.exe              308      4      2    29 2018-05-12 10:59:32 UTC+0000
0xfffffa8003d28700:winlogon.exe          564    452      5   118 2018-05-12 10:59:34 UTC+0000
0xfffffa8002f8a060:csrss.exe            472    452    10   373 2018-05-12 10:59:33 UTC+0000
. 0xfffffa80031ec1c0:conhost.exe          2860    472      2    56 2018-05-12 11:10:04 UTC+0000
. 0xfffffa8001ecf060:conhost.exe          3012    472      2    50 2018-05-12 11:11:37 UTC+0000
0xfffffa80020e7b00:ssms.exe              2972   2512      6   114 2018-05-12 11:11:23 UTC+0000
. 0xfffffa8001ecf660:cmd.exe              1988   2972      1    34 2018-05-12 11:11:37 UTC+0000
0xfffffa8003bfeb00:lsmb3mon.exe          2624   2580      4   100 2018-05-12 10:59:43 UTC+0000
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP#

```

ssms.exe est le Session Manager Subsystem. Cependant, nous pouvons voir ssms.exe qui est quelque chose d'inconnu et a été lancé automatiquement plus tard. De plus, ce dernier a lancé un processus : cmd.exe. Sur la machine il se situe dans :

C:\Users\boulet\AppData\Local\Temp\ssms.exe :

```

*****
ssms.exe pid: 2972
Command line : C:\Users\boulet\AppData\Local\Temp\ssms.exe
*****
cmd.exe pid: 1988
Command line : C:\Windows\system32\cmd.exe
*****
conhost.exe pid: 3012
Command line : \??\C:\Windows\system32\conhost.exe "-1792709212-239244628-708160973326086649-418271796376800906-15085624551878662238"
*****
WMIADAP.exe pid: 3360
Command line : wmiadap.exe /R /T
*****

```

Pour ce faire nous avons utilisé cmdline :

```

ipconfig.exe pid: 204
root@forensics-vm:/home/forensics/Bureau/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 cmdline

```

Nous pouvons extraire le fichier ssms.exe à l'aide de procdump :

```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 procdump -p 2972 -D .
Volatility Foundation Volatility Framework 2.6
Process(V)      ImageBase      Name           Result
-----
0xfffffa80020e7b00 0x0000000000400000 ssms.exe      OK: executable.2972.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# ls -l
total 2471660
-rw-r--r-- 1 root root 73728 juin 1 10:33 executable.2972.exe
-rw-r--r-- 1 root root 2359296 juin 1 09:57 file.None.0xfffffa80030e4e00.vacb
-rw-r--r-- 1 root root 1310720 juin 1 10:00 file.None.0xfffffa8003e45e00.vacb
-rw-r--r-- 1 root root 32768 juin 1 10:01 places.sqlite
-rw-rw-r-- 1 forensics forensics 327539777 janv. 26 2023 TP1-v2-Mem.7z
-rw-r--r-- 1 root root 2147483648 mai 12 2018 TP1-v2-Mem.raw
-rwxr-xr-x 1 forensics forensics 52168925 juin 10 2017 TP2-Mem.raw.7z
-rw-r--r-- 1 root root 1048576 juin 1 09:57 wal-16.dat

```

ssms.exe est un turbo trojan :

virustotal.com/gui/file/022b8256c06c3a26c03a09eeb096aa212d72426d6cefc0c2058e01322ddd8ad

Splunk CyberChef

022b8256c06c3a26c03a09eeb096aa212d72426d6cefc0c2058e01322ddd8ad

60/71 security vendors flagged this file as malicious

Reanalyze Similar More

022b8256c06c3a26c03a09eeb096aa212d72426d6cefc0c2058e01322ddd8ad

Size 72.00 KB Last Analysis Date 10 months ago

EXE

ab.exe

peexe

Community Score 60/71

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 2

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label trojan.swort/cryptz Threat categories trojan Family labels swort cryptz marte

Security vendors' analysis Do you want to automate checks?

Acronis (Static ML)	Suspicious	AhnLab-V3	Trojan:Win32.Shell.R1283
Alibaba	Trojan:Win32/CobaltStrike.5c89	AliCloud	Backdoor:Win/meterpreter.A

La commande strings nous montre des choses. Par exemple :

```
EnterCriticalSection
ReleaseMutex
SetEvent
LeaveCriticalSection
TerminateProcess
GetExitCodeProcess
GetVersionExA
GetProcAddress
LoadLibraryA
WriteFile
ReadFile
PeekNamedPipe
KERNEL32.dll
AllocateAndInitializeSid
FreeSid
ADVAPI32.dll
WSOCK32.dll
WSASend
WSARecv
WS2_32.dll
_strnicmp
_strdup
%s: Cannot use concurrency level greater than total number of requests
%s: Invalid Concurrency [Range 0..%d]
%s: Invalid URL
%s: wrong number of arguments
User-Agent:
Accept:
Host:
Proxy-Authorization: Basic
Proxy credentials too long
Authorization: Basic
Authentication credentials too long
Cookie:
Cannot mix PUT and HEAD
Cannot mix POST and HEAD
```

Son but est probablement de faire un stress-web pour que le PC de boulet devienne un botnet. Il a notamment utilisé Apache Benchmark :

```

Licensed to The Apache Software Foundation, http://www.apache.org/<br>
Copyright 1996 Adam Twiss, Zeus Technology Ltd, http://www.zeustech.net/<br>
This is ApacheBench, Version %s <i>&lt;%s&gt;</i><br>
$Revision: 655654 $
Licensed to The Apache Software Foundation, http://www.apache.org/
Copyright 1996 Adam Twiss, Zeus Technology Ltd, http://www.zeustech.net/
This is ApacheBench, Version %s
2.3 <$Revision: 655654 $>
-h          Display usage information (this message)
-r          Don't exit on socket receive errors.
-e filename Output CSV file with percentages served
-g filename Output collected data to gnuplot format file.
-S          Do not show confidence estimators and warnings.
-d          Do not show percentiles served table.
-k          Use HTTP KeepAlive feature
-V          Print version number and exit
-X proxy:port Proxyserver and port number to use
-P attribute Add Basic Proxy Authentication, the attributes
            are a colon separated username and password.
-A attribute Add Basic WWW Authentication, the attributes
            Inserted after all normal header lines. (repeatable)
-H attribute Add Arbitrary header line, eg. 'Accept-Encoding: gzip'
-C attribute Add cookie, eg. 'Apache=1234'. (repeatable)
-z attributes String to insert as td or th attributes
-y attributes String to insert as tr attributes
-x attributes String to insert as table attributes
-i          Use HEAD instead of GET
-w          Print out results in HTML tables
-v verbosity How much troubleshooting info to print
            Default is 'text/plain'
            'application/x-www-form-urlencoded'
-T content-type Content-type header for POSTing, eg.
-u putfile   File containing data to PUT. Remember also to set -T
-p postfile  File containing data to POST. Remember also to set -T
-b window-size Size of TCP send/receive buffer, in bytes
-t timelimit Seconds to max. wait for responses
            Default is 30 seconds

```

- Quelles actions ont été effectuées par le processus incriminé ? Y avait-il une activité réseau anormale ?

Avec consoles, nous pouvons voir ce qui était écrit sur le CMD. Nous trouvons notamment une tentative de ping vers un serveur étrange :

```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 consoles

```

```

C:\Users\boulet>ipconfig

Configuration IP de Windows

Carte Ethernet Connexion au r?seau local 2 :

    Suffixe DNS propre ? la connexion. . . : home.local
    Adresse IPv6 de liaison locale. . . . : fe80::7db1:145c:6709:ced4%13
    Adresse IPv4. . . . . : 192.168.0.226
    Masque de sous-r?seau. . . ?. . . . : 255.255.255.0
    Passerelle par d?faut. . . ?. . . . : 192.168.0.1

```

```

C:\Users\boulet>ping cc.mounhack.fr

Envoi d'une requ?te 'ping' sur cc.mounhack.fr [5.196.180.55] avec 32 octets de d
onn?es?:
R?ponse de 5.196.180.55?: octets=32 temps=34 ms TTL=52
R?ponse de 5.196.180.55?: octets=32 temps=34 ms TTL=52
R?ponse de 5.196.180.55?: octets=32 temps=35 ms TTL=52
R?ponse de 5.196.180.55?: octets=32 temps=38 ms TTL=52

```

Pour l'activité réseau nous passons par netscan, cependant, nous trouvons une connexion d'établie justement vers ce site :

```
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 netscan
```

Offset(P)	Proto	Local Address	Foreign Address	State	Pid	Owner	Created
0x59e87c0	TCPv4	127.0.0.1:49570	127.0.0.1:49571	ESTABLISHED	-1		
0x7cb66890	TCPv4	127.0.0.1:49158	127.0.0.1:49159	ESTABLISHED	-1		
0x7d0f5bb0	UDPv6	fe80::7db1:145c:6709:ced4:1900	*:*		3632	svchost.exe	2018-05-12 11:01:36
UTC+0000							
0x7d3d0ec0	UDPv4	192.168.0.226:1900	*:*		3632	svchost.exe	2018-05-12 11:01:36
UTC+0000							
0x7d42aec0	UDPv4	192.168.0.226:137	*:*		4	System	2018-05-12 10:59:36
UTC+0000							
0x7d461ec0	UDPv4	0.0.0.0:0	*:*		1036	svchost.exe	2018-05-12 11:12:17
UTC+0000							
0x7d461ec0	UDPv6	:::0	*:*		1036	svchost.exe	2018-05-12 11:12:17
UTC+0000							
0x7d472c00	UDPv4	0.0.0.0:5355	*:*		1036	svchost.exe	2018-05-12 11:12:17
UTC+0000							
0x7d5173c0	UDPv6	:::1:64367	*:*		3632	svchost.exe	2018-05-12 11:01:36
UTC+0000							
0x7d647b30	UDPv4	0.0.0.0:5355	*:*		1036	svchost.exe	2018-05-12 11:12:17
UTC+0000							
0x7d647b30	UDPv6	:::5355	*:*		1036	svchost.exe	2018-05-12 11:12:17
UTC+0000							
0x7d465720	TCPv6	:::3389	:::0	LISTENING	1036	svchost.exe	
0x7d47b8a0	TCPv4	0.0.0.0:3389	0.0.0.0:0	LISTENING	1036	svchost.exe	
0x7d848e20	TCPv4	0.0.0.0:135	0.0.0.0:0	LISTENING	752	svchost.exe	
0x7d84c2e0	TCPv4	0.0.0.0:135	0.0.0.0:0	LISTENING	752	svchost.exe	
0x7d84c2e0	TCPv6	:::135	:::0	LISTENING	752	svchost.exe	
0x7d862200	TCPv4	0.0.0.0:49152	0.0.0.0:0	LISTENING	460	wininit.exe	
0x7d862200	TCPv6	:::49152	:::0	LISTENING	460	wininit.exe	
0x7d865c10	TCPv4	0.0.0.0:49152	0.0.0.0:0	LISTENING	460	wininit.exe	
0x7d882bc0	TCPv4	0.0.0.0:49153	0.0.0.0:0	LISTENING	804	svchost.exe	
0x7d8845f0	TCPv4	0.0.0.0:49153	0.0.0.0:0	LISTENING	804	svchost.exe	
0x7d8845f0	TCPv6	:::49153	:::0	LISTENING	804	svchost.exe	
0x7d89e710	TCPv4	0.0.0.0:49154	0.0.0.0:0	LISTENING	1012	svchost.exe	
0x7d99a0c0	TCPv4	0.0.0.0:49154	0.0.0.0:0	LISTENING	1012	svchost.exe	
0x7d99a0c0	TCPv6	:::49154	:::0	LISTENING	1012	svchost.exe	
0x7de18840	TCPv4	192.168.0.226:49831	5.196.180.55:31337	ESTABLISHED	-1		
0x7de816e0	TCPv4	127.0.0.1:49168	127.0.0.1:49167	ESTABLISHED	-1		
0x7de83a70	TCPv4	127.0.0.1:49167	127.0.0.1:49168	ESTABLISHED	-1		
0xe7e19db10	TCPv4	127.0.0.1:49159	127.0.0.1:49158	ESTABLISHED	-1		
0xe7e78dec0	UDPv6	:::1:1900	*:*		3632	svchost.exe	2018-05-12 11:01:36
UTC+0000							
0xe7e662cd0	TCPv4	127.0.0.1:49161	127.0.0.1:49160	ESTABLISHED	-1		
0xe7e663010	TCPv4	127.0.0.1:49160	127.0.0.1:49161	ESTABLISHED	-1		
0xf709c320	UDPv4	127.0.0.1:64368	*:*		3632	svchost.exe	2018-05-12 11:01:36

L'IP 5.196.180.55 correspond à l'IP que nous avons sur le ping.

L'IP source 192.168.0.226 est bien celle de la machine (voir questions ci-dessus)

Le port distant utilisé est 31337 (ELEET = ELITE), c'est du Leet Speak.

Le port source est 49831.

Le PID à -1 signifie probablement que le pirate a voulu dissimuler sa connexion sur la machine (probablement avec un malware).

En résumé, ssms.exe a ouvert un CMD qui a initié une connexion vers ce serveur malveillant sur le port 31337.

- Que faisait l'utilisateur connecté ?

D'après, ce que nous avons trouvé plus haut, l'utilisateur naviguait simplement sur Internet. Il y a plusieurs instances de firefox.exe qui tournaient dans le pstree. Nous pouvons essayer de récupérer son historique :


```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 ffilescan | grep -l "places.sqlite"
Volatility Foundation Volatility Framework 2.6
0x00000000d379dd0 1 1 R--rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite
0x000000007d1185b0 17 1 RW-rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite-shm
0x000000007d1bf070 1 1 RW-rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite-wal
0x000000007e18d070 1 1 R--rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite
0x000000007e658e50 1 1 R--rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite
0x000000007e699f20 1 1 RW-rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite-wal
0x000000007e6df710 1 1 RW-rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite-wal
0x000000007e6df710 26 1 RW-rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite-wal
0x000000007e900c30 11 1 RW-rw- \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\place
s.sqlite
root@forensics-vm:/home/forensics/Cases/2_MEM/TP#

```

wal signifie Write Ahead Log, ce sont eux, qui contiennent l'historique. Nous allons choisir celles qui ont les plus grand pointeurs (26 et 11) car ce sont sûrement eux les plus complets.

On dump alors leur contenu en spécifiant l'offset de l'adresse mémoire (-Q) et le lieu où exporter les fichiers extraits (-D) :

```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 dumpfiles -Q 0x000000007e6df710 -D .
Volatility Foundation Volatility Framework 2.6
DataSectionObject 0x7e6df710 None \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\places.
sqlite-wal
SharedCacheMap 0x7e6df710 None \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\places.sql
ite-wal
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# ls -l
total 2470276
-rw-r--r-- 1 root root 2359296 juin 1 09:57 file.None.0xfffffa80030e4e00.vacb
-rw-r--r-- 1 root root 1048576 juin 1 09:57 file.None.0xfffffa8004839ba0.dat
-rw-rw-r-- 1 forensics forensics 327539777 janv. 26 2023 TP1-v2-Mem.7z
-rw----- 1 root root 2147483648 mai 12 2018 TP1-v2-Mem.raw
-rwxr-xr-x 1 forensics forensics 52168925 juin 10 2017 TP2-Mem.raw.7z
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# mv file.None.0xfffffa8004839ba0.dat wal-16.dat
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 dumpfiles -Q 0x000000007e900c30 -D .
Volatility Foundation Volatility Framework 2.6
DataSectionObject 0x7e900c30 None \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\places.
sqlite
SharedCacheMap 0x7e900c30 None \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\places.sql
ite
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# ls -l
total 2471556
-rw-r--r-- 1 root root 2359296 juin 1 09:57 file.None.0xfffffa80030e4e00.vacb
-rw-r--r-- 1 root root 1310720 juin 1 10:00 file.None.0xfffffa8003e45e00.vacb
-rw-rw-r-- 1 forensics forensics 327539777 janv. 26 2023 TP1-v2-Mem.7z
-rw----- 1 root root 2147483648 mai 12 2018 TP1-v2-Mem.raw
-rwxr-xr-x 1 forensics forensics 52168925 juin 10 2017 TP2-Mem.raw.7z
-rw-r--r-- 1 root root 1048576 juin 1 09:57 wal-16.dat

```

```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 dumpfiles -Q 0x000000007d1185b0 -D .
Volatility Foundation Volatility Framework 2.6
DataSectionObject 0x7d1185b0 None \Device\HarddiskVolume2\Users\boulet\AppData\Roaming\Mozilla\Firefox\Profiles\kuipjvl3.default\places.
sqlite-shm
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# ls -l
total 2471588
-rw-r--r-- 1 root root 32768 juin 1 10:01 file.None.0xfffffa80030dccb0.dat
-rw-r--r-- 1 root root 2359296 juin 1 09:57 file.None.0xfffffa80030e4e00.vacb
-rw-r--r-- 1 root root 1310720 juin 1 10:00 file.None.0xfffffa8003e45e00.vacb
-rw-rw-r-- 1 forensics forensics 327539777 janv. 26 2023 TP1-v2-Mem.7z
-rw----- 1 root root 2147483648 mai 12 2018 TP1-v2-Mem.raw
-rwxr-xr-x 1 forensics forensics 52168925 juin 10 2017 TP2-Mem.raw.7z
-rw-r--r-- 1 root root 1048576 juin 1 09:57 wal-16.dat
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# mv file.None.0xfffffa80030dccb0.dat places.sqlite
root@forensics-vm:/home/forensics/Cases/2_MEM/TP#

```

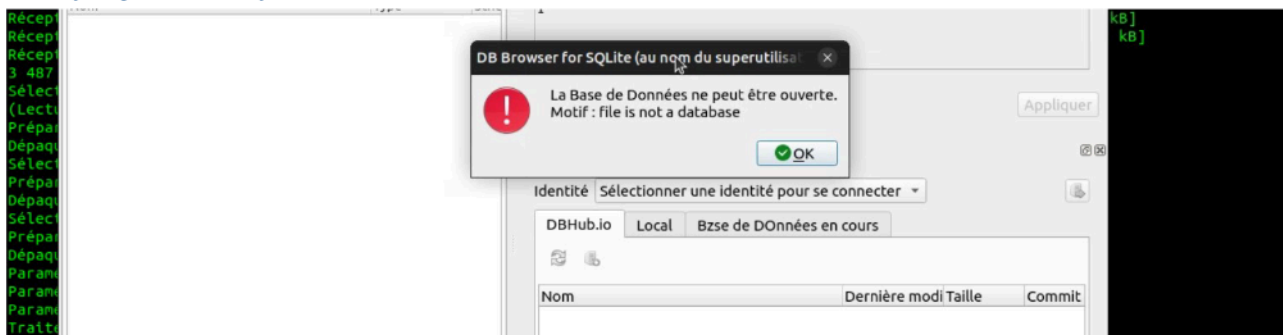
Pour le deuxième fichier traité, il n'y a pas eu fichier dat en sortie. Donc pas de donnée particulière à récupérer. Nous allons maintenant devoir utiliser sqlite :


```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# apt install sqlitebrowser
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
Les paquets suivants ont été installés automatiquement et ne sont plus nécessaires :
  libllvm13 libllvm13:i386
Veuillez utiliser « sudo apt autoremove » pour les supprimer.
Les paquets supplémentaires suivants seront installés :
  libqscintilla2-qt5-15 libqscintilla2-qt5-15on
Paquets suggérés :
  libqscintilla2-doc
Les NOUVEAUX paquets suivants seront installés :
  libqscintilla2-qt5-15 libqscintilla2-qt5-15on sqlitebrowser
0 mis à jour, 3 nouvellement installés, 0 à enlever et 102 non mis à jour.
Il est nécessaire de prendre 3 487 ko dans les archives.
Après cette opération, 10,6 Mo d'espace disque supplémentaires seront utilisés.
Souhaitez-vous continuer ? [O/n]

```

Tant pis ça marche pas :



Un strings sur le fichier wal-16 suffisait au final.

Boulet faisait du reverse engineering :

```

l;+
https://www.google.com/search?q=news&le=utf-8&oe=utf-8&client=firefox-b-abnews - Recherche Googlemoc.elgoog.www.
dJoVjtGunble+
file:///C:/Users/boulet/Downloads/xpose_quentin-bernard_reverse-engineering.pdfxpose_quentin-bernard_reverse-engineering.pdf.d
k^me
hv8z5_NXGuEY
cg-
http://igm.univ-mlv.fr/~dr/XPOSE2013/reverse_engineering/pres/xpose_quentin-bernard_reverse-engineering.pdfxpose_quentin-bernard_reverse-eng
ineering.pdfrrf.vlm-vinu.mgl."
RpGHHqSnZxBY9_r&
https://www.cs.tau.ac.il/~tromer/courses/infosec11/lecture9.pdfIntroduction to Reverse Engineering - lecture9.pdfll.ca.uat.sc.www.d
0rPgHH6BNyZSG+
W.5k
3a+
https://www.google.com/search?client=firefox-b-ab&el=fbv2WpKoFcPogAbEgon4Cw&q=reverse+engineering+pdf&oq=reverse+engineering+pdf&gs_l=psy-ab
.3..0j0l22i30k1l7j0l22i10l30k1j0l22i30k1.16120.25396.0.25502.44.25.18.0.0.0.182.2296.10j11.21.0...0...1.1.64.psy-ab..5.39.2370...0i67k1j0l1
31k1j0i131i67k1j0i19k1j0i10i19k1j0i22i30i19k1.0.7EcLdRqnCm4reverse engineering pdf - Recherche Googlemoc.elgoog.www.d
tWMMPdHhOfjH+
-G+
https://www.google.com/search?q=pdf+viewer&le=utf-8&oe=utf-8&client=firefox-b-abpdf viewer - Recherche Googlemoc.elgoog.www.
k^gC
XPM4xdPcY7nY+
https://www.7-zip.org/a/7z1805-x64.exe7z1805-x64.exegro.piz-7.www.

```

Tout en écoutant du Marwa Loud :

```

https://www.youtube.com/watch?v=sz9gLPALoNcMarwa Loud - Je Voulais ft. Laguardia (Clip Officiel) - YouTubemoc.ebutuoy.www.d
xXkvbZ2r5y8YR+
l;+

```

En lisant le jdd et heb'di :

```

nahttps://cdn1-lejdd.ladmedia.fr/var/europa1/storage/images/lejdd/International/john-mccain-va-mourir-de-toute-facon-les-propos-dune-employe
e-de-la-maison-blanche-font-polemique-3650039/48150794-1-fre-FR/John-McCain-va-mourir-de-toute-facon-les-propos-d-une-employee-de-la-Maison-
Blanche-font-polemique.jpg
https://news.url.google.com/url?sa=j&url=https%3A%2F%2Fwww.lejdd.fr%2Finternational%2Fjohn-mccain-va-mourir-de-toute-facon-les-propos-dune-
mployee-de-la-maison-blanche-font-polemique-3650039&uct=1526119007&usq=44bqZbr23p_ZAX55gXh5wXkc1Jg.moc.elgoog.lru.swen.d
HBQbAVlIB4KHJ+
Khttps://www.hebdi.com/operatrices-samu-se-moquent-de-naomi-jeune-maman-decede-quelques-heures-plus-tard-enregistrement/Les op
ratrices du SAMU se moquent de Naomi... La jeune maman d
de quelques heures plus tard ! (enregistrement) - Hebdi.moc.idbeh.www.d
LXepSHf8tPf3+
Les op
ratrices du SAMU se moquent de Naomi
La jeune maman d
de quelques heures plus tard ! Le 29 d
cembre 2017, 11 heures. Prise de tr
s fortes douleurs, Naomi,
bout de force appelle le SAMU de Strasbourg. Comme l
indique l
enregistrement
les deux ohhttps://www.hebdi.com/wp-content/uploads/2018/04/Land_Rover_SMUR_-_SAMU_67_Strasbourg_VLM_1.jpg
s1-

```

Et en naviguant sur JVC :

```

http://jeuxvideos.com/moc.soedlvxuej.
SpCeICTvbgMTU-r&ue
mhhttps://www.lejdd.fr/international/john-mccain-va-mourir-de-toute-facon-les-propos-dune-employee-de-la-maison-blanche-font-polemique-365003
9John McCain "va mourir de toute fa
on" : les propos d'une employ
e de la Maison-Blanche font pol
miquerf.ddjel.www.d
NQ-fqHueRnKi+
Ce &quot;n'est pas grave&quot; car &quot;il va mourir de toute fa
on&quot;; a d
clar
une employ
e de la Maison-Blanche,
propos de l'opposition de John McCain
la nomination&nbsp;de&nbsp;Gina Haspel&nbsp;
la t
te de la CIA. La femme et la fille du s

```

- Qu'y a-t-il sur le lecteur trouvé ?

Déjà, nous avons trouvé une clé USB :

```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 printkey -K "ControlSet001\Enum\USBSTOR"
Volatility Foundation Volatility Framework 2.6
Legend: (S) = Stable (V) = Volatile

-----
Registry: \REGISTRY\MACHINE\SYSTEM
Key name: USBSTOR (S)
Last updated: 2018-05-12 11:10:47 UTC+0000

Subkeys:
(S) Disk&Ven_SanDisk&Prod_Ultra_Fit&Rev_1.00

Values:
root@forensics-vm:/home/forensics/Cases/2_MEM/TP#

```

C'est une SanDisk UltraFit.

Puis, la liste des lecteurs :

```

root@forensics-vm:/home/forensics/Cases/2_MEH/TP# volatility -f TP1-v2-Mem.raw --profile=Wln7SP1x64 printkey -K "MountedDevices"
Volatility Foundation Volatility Framework 2.6
Legend: (S) = Stable (V) = Volatile

-----
Registry: \REGISTRY\MACHINE\SYSTEM
Key name: MountedDevices (S)
Last updated: 2018-05-12 11:10:48 UTC+0000

Subkeys:

Values:
REG_BINARY \DosDevices\C: : (S)
0x00000000 e5 c9 88 71 00 00 50 06 00 00 00 00 ...q..P....
REG_BINARY \??\Volume{38d237c4-efa6-11e7-8272-806e6f6e6963} : (S)
0x00000000 e5 c9 88 71 00 00 10 00 00 00 00 00 ...q.....
REG_BINARY \??\Volume{38d237c5-efa6-11e7-8272-806e6f6e6963} : (S)
0x00000000 e5 c9 88 71 00 00 50 06 00 00 00 00 ...q..P....
REG_BINARY \??\Volume{38d237c8-efa6-11e7-8272-806e6f6e6963} : (S)
0x00000000 5c 00 3f 00 3f 00 5c 00 49 00 44 00 45 00 23 00 \.?.?.\..I.D.E.#.
0x00000010 43 00 64 00 52 00 6f 00 6d 00 4e 00 45 00 43 00 C.d.R.o.m.N.E.C.
0x00000020 56 00 4d 00 57 00 61 00 72 00 5f 00 56 00 4d 00 V.M.W.a.r..V.M.
0x00000030 77 00 61 00 72 00 65 00 5f 00 53 00 41 00 54 00 w.a.r.e..S.A.T.
0x00000040 41 00 5f 00 43 00 44 00 30 00 30 00 5f 00 5f 00 A..C.D.O.._.
0x00000050 5f 00 5f 00 5f 00 5f 00 5f 00 5f 00 5f 00 5f 00 _._._._._.1...0.
0x00000060 5f 00 5f 00 5f 00 5f 00 5f 00 31 00 2e 00 30 00 _._._._._.1...0.
0x00000070 30 00 5f 00 5f 00 5f 00 5f 00 23 00 36 00 26 00 0.._._._.#.6.&.
0x00000080 31 00 64 00 61 00 36 00 64 00 63 00 64 00 64 00 1.d.a.6.d.c.d.d.
0x00000090 26 00 30 00 26 00 30 00 2e 00 30 00 2e 00 30 00 8.0.8.0...0...0.
0x000000a0 23 00 7b 00 35 00 33 00 66 00 35 00 36 00 33 00 #.{.5.3.f.5.6.3.
0x000000b0 30 00 64 00 2d 00 62 00 36 00 62 00 66 00 2d 00 0.d.-.b.6.b.f.-.
0x000000c0 31 00 31 00 64 00 30 00 2d 00 39 00 34 00 66 00 1.1.d.0.-.9.4.f.
0x000000d0 32 00 2d 00 30 00 30 00 61 00 30 00 63 00 39 00 2.-.0.0.a.0.c.9.
0x000000e0 31 00 65 00 66 00 62 00 38 00 62 00 7d 00 1.e.f.b.8.b.).
REG_BINARY \DosDevices\D: : (S)

```

```

REG_BINARY \??\Volume{89df53b1-55d3-11e8-ae18-000c29f053e8} : (S)
0x00000000 5f 00 3f 00 3f 00 5f 00 55 00 53 00 42 00 53 00 _..?..U.S.B.S.
0x00000010 54 00 4f 00 52 00 23 00 44 00 69 00 73 00 6b 00 T.O.R.#.D.l.s.k.
0x00000020 26 00 56 00 65 00 6e 00 5f 00 53 00 61 00 6e 00 &V.e.n..S.a.n.
0x00000030 44 00 69 00 73 00 6b 00 26 00 50 00 72 00 6f 00 D.l.s.k.&P.r.o.
0x00000040 64 00 5f 00 55 00 6c 00 74 00 72 00 61 00 5f 00 d..U.l.t.r.a..
0x00000050 46 00 69 00 74 00 26 00 52 00 65 00 76 00 5f 00 F.l.t.&R.e.v..
0x00000060 31 00 2e 00 30 00 30 00 23 00 34 00 43 00 35 00 1...0.0.#.4.C.5.
0x00000070 33 00 30 00 30 00 30 00 31 00 30 00 35 00 30 00 3.0.0.0.1.0.5.0.
0x00000080 34 00 30 00 31 00 31 00 30 00 31 00 33 00 35 00 4.0.1.1.0.1.3.5.
0x00000090 32 00 26 00 30 00 23 00 7b 00 35 00 33 00 66 00 2.&.0.#.{.5.3.f.
0x000000a0 35 00 36 00 33 00 30 00 37 00 2d 00 62 00 36 00 5.6.3.0.7.-.b.6.
0x000000b0 62 00 66 00 2d 00 31 00 31 00 64 00 30 00 2d 00 b.f.-.1.1.d.0.-.
0x000000c0 39 00 34 00 66 00 32 00 2d 00 30 00 30 00 61 00 9.4.f.2.-.0.0.a.
0x000000d0 30 00 63 00 39 00 31 00 65 00 66 00 62 00 38 00 0.c.9.1.e.f.b.8.
0x000000e0 62 00 7d 00 b.).
REG_BINARY \DosDevices\E: : (S)
0x00000000 5f 00 3f 00 3f 00 5f 00 55 00 53 00 42 00 53 00 _..?..U.S.B.S.
0x00000010 54 00 4f 00 52 00 23 00 44 00 69 00 73 00 6b 00 T.O.R.#.D.l.s.k.
0x00000020 26 00 56 00 65 00 6e 00 5f 00 53 00 61 00 6e 00 &V.e.n..S.a.n.
0x00000030 44 00 69 00 73 00 6b 00 26 00 50 00 72 00 6f 00 D.l.s.k.&P.r.o.
0x00000040 64 00 5f 00 55 00 6c 00 74 00 72 00 61 00 5f 00 d..U.l.t.r.a..
0x00000050 46 00 69 00 74 00 26 00 52 00 65 00 76 00 5f 00 F.l.t.&R.e.v..
0x00000060 31 00 2e 00 30 00 30 00 23 00 34 00 43 00 35 00 1...0.0.#.4.C.5.
0x00000070 33 00 30 00 30 00 30 00 31 00 30 00 35 00 30 00 3.0.0.0.1.0.5.0.
0x00000080 34 00 30 00 31 00 31 00 30 00 31 00 33 00 35 00 4.0.1.1.0.1.3.5.
0x00000090 32 00 26 00 30 00 23 00 7b 00 35 00 33 00 66 00 2.&.0.#.{.5.3.f.
0x000000a0 35 00 36 00 33 00 30 00 37 00 2d 00 62 00 36 00 5.6.3.0.7.-.b.6.
0x000000b0 62 00 66 00 2d 00 31 00 31 00 64 00 30 00 2d 00 b.f.-.1.1.d.0.-.
0x000000c0 39 00 34 00 66 00 32 00 2d 00 30 00 30 00 61 00 9.4.f.2.-.0.0.a.
0x000000d0 30 00 63 00 39 00 31 00 65 00 66 00 62 00 38 00 0.c.9.1.e.f.b.8.
0x000000e0 62 00 7d 00 b.).
root@forensics-vm:/home/forensics/Cases/2_MEH/TP#

```

La clé USB occupe le lecteur E :

Elle contient notamment un fichier nommé RemoteAccess :


```

0x000000007c8bfb90 4 0 RW-rwd \Device\HarddiskVolume1\SftMirr
0x000000007ca0a900 4 0 RW-rwd \Device\HarddiskVolume1\SftMap
0x000000007cb219d0 26 0 RW-rwd \Device\HarddiskVolume1\Sft
0x000000007cd898e0 18 0 RW-rwd \Device\HarddiskVolume1\Sft
0x000000007ce9d60 2 1 RNDrwd \Device\Clfs\Device\HarddiskVolume3\Extend\SRmMetadata\TxfLog\TxfLog
0x000000007ceefd60 15 0 R--r-- \Device\HarddiskVolume3\RemoteAccess.exe
0x000000007d0aa290 2 1 R--rwd \Device\HarddiskVolume3\
0x000000007d36b3e0 18 0 RW-rwd \Device\HarddiskVolume1\SDirectory
0x000000007d418d40 2 1 RW-r-- \Device\HarddiskVolume3\Extend\SRmMetadata\TxfLog\TxfLogContainer00000000000000000002
0x000000007d474dc0 18 0 RW-rwd \Device\HarddiskVolume3\SftMap
0x000000007d5eaf20 1 0 RW-rwd \Device\HarddiskVolume1\SDirectory
0x000000007d622b60 2 1 RNDrwd \Device\Clfs\Device\HarddiskVolume3\Extend\SRmMetadata\TxfLog\TxfLog
0x000000007d821950 2 1 R--rwd \Device\HarddiskVolume3\
0x000000007d89e500 1 1 RW-rwd \Device\Clfs\Device\HarddiskVolume3\Extend\SRmMetadata\TxfLog\TxfLog
0x000000007da826b0 24 0 RW-rwd \Device\HarddiskVolume3\Sft
0x000000007dd08dd0 18 0 RW-rwd \Device\HarddiskVolume3\SDirectory
0x000000007e1a1f20 18 0 RW-rwd \Device\HarddiskVolume3\Sft
0x000000007e35e7d0 2 1 RNDrwd \Device\Clfs\Device\HarddiskVolume1\Extend\SRmMetadata\TxfLog\TxfLog
0x000000007e3c01a0 1 1 RW-rwd \Device\Clfs\Device\HarddiskVolume1\Extend\SRmMetadata\TxfLog\TxfLog
0x000000007e40a500 18 0 RW-rwd \Device\HarddiskVolume3\SDirectory
0x000000007e77f330 2 1 RNDrwd \Device\Clfs\Device\HarddiskVolume1\Extend\SRmMetadata\TxfLog\TxfLog
0x000000007e77f6c0 33 0 RW-rwd \Device\HarddiskVolume1\SDirectory
0x000000007e77f8a0 1 1 RW--- \Device\HarddiskVolume3\Boot\BCD.LOG
0x000000007e7c7240 2 1 RW-r-- \Device\HarddiskVolume1\Extend\SRmMetadata\TxfLog\TxfLogContainer00000000000000000002
0x000000007e9bd710 16 0 RW-rwd \Device\HarddiskVolume3\LogFile
0x000000007f677760 2 1 RW-r-- \Device\HarddiskVolume3\Extend\SRmMetadata\TxfLog\TxfLog.blf
0x000000007f681e60 18 0 RW-rwd \Device\HarddiskVolume3\SftMirr
0x000000007f6c34a0 2 1 RW-r-- \Device\HarddiskVolume3\Extend\SRmMetadata\TxfLog\TxfLogContainer00000000000000000001
0x000000007f6c1a2f0 2 1 R--rwd \Device\HarddiskVolume3\fs.events
0x000000007fccbdc0 15 0 R--r-d \Device\HarddiskVolume3\RemoteAccess.exe
0x000000007fce43f0 2 1 R--rwd \Device\HarddiskVolume3\Trashes
0x000000007fd3b960 1 0 RW-rwd \Device\HarddiskVolume3\SDirectory
0x000000007fe01f20 2 1 R--rwd \Device\HarddiskVolume3\fs.events
0x000000007fe0b890 2 1 R--rwd \Device\HarddiskVolume3\Trashes
root@forensics-vm:/home/forensics/Cases/2_MEM/TP#

```

```

Volatility Foundation Volatility Framework 2.6
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 filescan | grep -l "HarddiskVolume" | gr
ep -v "HarddiskVolume2"

```

Nous allons essayer de le récupérer pour l'analyser :

```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 dumpfiles -Q 0x000000007ceefd60 -D .
Volatility Foundation Volatility Framework 2.6
ImageSectionObject 0x7ceefd60 None \Device\HarddiskVolume3\RemoteAccess.exe
DataSectionObject 0x7ceefd60 None \Device\HarddiskVolume3\RemoteAccess.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# ls -l
total 2536372
-rw-r--r-- 1 root root 2359296 juin 1 09:57 file.None.0xfffffa80030e4e00.vacb
-rw-r--r-- 1 root root 110592 juin 1 11:59 file.None.0xfffffa8003314010.dat
-rw-r--r-- 1 root root 1310720 juin 1 10:00 file.None.0xfffffa8003e45e00.vacb
-rw-r--r-- 1 root root 110080 juin 1 11:59 file.None.0xfffffa80048e8590.img
-rw-r--r-- 1 root root 66244174 juin 1 11:10 mft_analyse.txt
-rw-r--r-- 1 root root 32768 juin 1 10:01 places.sqlite
-rw-r--r-- 1 root root 73728 juin 1 10:33 ssms.exe
-rw-rw-r-- 1 forensics forensics 327539777 janv. 26 2023 TP1-v2-Mem.7z
-rw-r--r-- 1 root root 2147483648 mai 12 2018 TP1-v2-Mem.raw
-rwxr-xr-x 1 forensics forensics 52168925 juin 10 2017 TP2-Mem.raw.7z
-rw-r--r-- 1 root root 1048576 juin 1 09:57 wal-16.dat

```

On fait un petit mv pour le mettre sous la forme d'un exe :

```

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# mv file.None.0xfffffa8003314010.dat RemoteAccess.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# ls -l
total 2536372
-rw-r--r-- 1 root root 2359296 juin 1 09:57 file.None.0xfffffa80030e4e00.vacb
-rw-r--r-- 1 root root 1310720 juin 1 10:00 file.None.0xfffffa8003e45e00.vacb
-rw-r--r-- 1 root root 110080 juin 1 11:59 file.None.0xfffffa80048e8590.img
-rw-r--r-- 1 root root 66244174 juin 1 11:10 mft_analyse.txt
-rw-r--r-- 1 root root 32768 juin 1 10:01 places.sqlite
-rw-r--r-- 1 root root 110592 juin 1 11:59 RemoteAccess.exe
-rw-r--r-- 1 root root 73728 juin 1 10:33 ssms.exe
-rw-rw-r-- 1 forensics forensics 327539777 janv. 26 2023 TP1-v2-Mem.7z
-rw-r--r-- 1 root root 2147483648 mai 12 2018 TP1-v2-Mem.raw
-rwxr-xr-x 1 forensics forensics 52168925 juin 10 2017 TP2-Mem.raw.7z
-rw-r--r-- 1 root root 1048576 juin 1 09:57 wal-16.dat

```


D'après VirusTotal, RemoteAccess.exe n'est pas un virus :

0 / 60
Community Score

No security vendors flagged this file as malicious

b1a986990b193f5661ce48a88c23a1fc7f19ec5d355038c087fa9f731708d385

RemoteAccess.exe

Size: 108.00 KB
Last Analysis Date: a moment ago

DETECTION DETAILS COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Acronis (Static ML)	Undetected	AhnLab-V3	Undetected
AliCloud	Undetected	ALYac	Undetected
Antiy-AVL	Undetected	Arcabit	Undetected

Ainsi, cela doit juste être un exécutable permettant de réaliser un accès à distance vers le PC de l'attaquant / vers une victime du DDoS.

- Peut-on trouver ce que contient le lecteur ailleurs ?

Le jeune boulet a copié le fichier vers son bureau :

```
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Wln7SP1x64 ffilescan | grep -i "RemoteAccess"
Volatility Foundation Volatility Framework 2.6
0x000000007ceefd60 15 0 R--r-- \Device\HarddiskVolume3\RemoteAccess.exe
0x000000007d36e520 16 0 RW---- \Device\HarddiskVolume2\Users\boulet\Desktop\RemoteAccess.exe
0x000000007d36eb70 16 0 -W-rwd \Device\HarddiskVolume2\Users\boulet\Desktop\RemoteAccess.exe
0x000000007dbfa4b0 16 0 -W-rwd \Device\HarddiskVolume2\Users\boulet\Desktop\RemoteAccess.exe
0x000000007f892f20 13 0 R--r-d \Device\HarddiskVolume2\Users\boulet\Desktop\RemoteAccess.exe
0x000000007fccbddd 15 0 R--r-d \Device\HarddiskVolume3\RemoteAccess.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP#
```

Il a probablement été exécuté.

Cependant, nous ne pouvons pas l'analyser :

```
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# mv 0x000000007d36eb70 RemoteAccess_Bureau.exe
mv: impossible d'évaluer '0x000000007d36eb70': Aucun fichier ou dossier de ce nom
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# mv file.None.0xfffffa8004870460.dat RemoteAccess_Bureau.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# ls -l
total 2536376
-rw-r--r-- 1 root root 2359296 juin 1 09:57 file.None.0xfffffa80030e4e00.vacb
-rw-r--r-- 1 root root 1310720 juin 1 10:00 file.None.0xfffffa8003e45e00.vacb
-rw-r--r-- 1 root root 110080 juin 1 11:59 file.None.0xfffffa80048e8590.img
-rw-r--r-- 1 root root 66244174 juin 1 11:10 mft_analyse.txt
-rw-r--r-- 1 root root 32768 juin 1 10:01 places.sqlite
-rw-r--r-- 1 root root 4096 juin 2 16:57 RemoteAccess_Bureau.exe
-rw-r--r-- 1 root root 110592 juin 1 11:59 RemoteAccess.exe
-rw-r--r-- 1 root root 73728 juin 1 10:33 ssms.exe
-rw-r--r-- 1 forensics forensics 327539777 janv. 26 2023 TP1-v2-Mem.7z
-rw-r--r-- 1 root root 2147483648 mai 12 2018 TP1-v2-Mem.raw
-rwxr-xr-x 1 forensics forensics 52168925 juin 10 2017 TP2-Mem.raw.7z
-rw-r--r-- 1 root root 1048576 juin 1 09:57 wal-16.dat
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# strings -el RemoteAccess_Bureau.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# strings RemoteAccess_Bureau.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP#
```

- Est-ce que le fichier trouvé a été exécuté sur le système ?

- -W-rwd (à expliquer)

Ici on a donc les droits suivants :

- W : ce handle peut écrire mais pas lire ni supprimer
- rwd : les autres processus peuvent lire, écrire et supprimer

- Quelles informations peut-on extraire des différents exécutables trouvés ?

remoteAccess.exe → réalisation d'un accès à distance probablement vers le PC de l'attaquant.

```
C:\Users\wagga\Desktop\SimpleMalware\Release\SimpleMalware.pdb
```

```
CONOUT$
banana.exe
XYZ
SOFTWARE\Microsoft\Windows\CurrentVersion\Run
```

```
$ root@forensics-vm /h/f/C/2/TP : volatiltty -f IP1-v2-Mem.raw --profile=Wln7SPix64 printkey -K "Microsoft\Windows\CurrentVersion\Run"
Volatiltty Foundation Volatiltty Framework 2.6
Legend: (S) = Stable (V) = Volatile

-----
Registry: \SystemRoot\System32\Config\SOFTWARE
Key name: Run (S)
Last updated: 2018-05-12 11:11:23 UTC+0000

Subkeys:

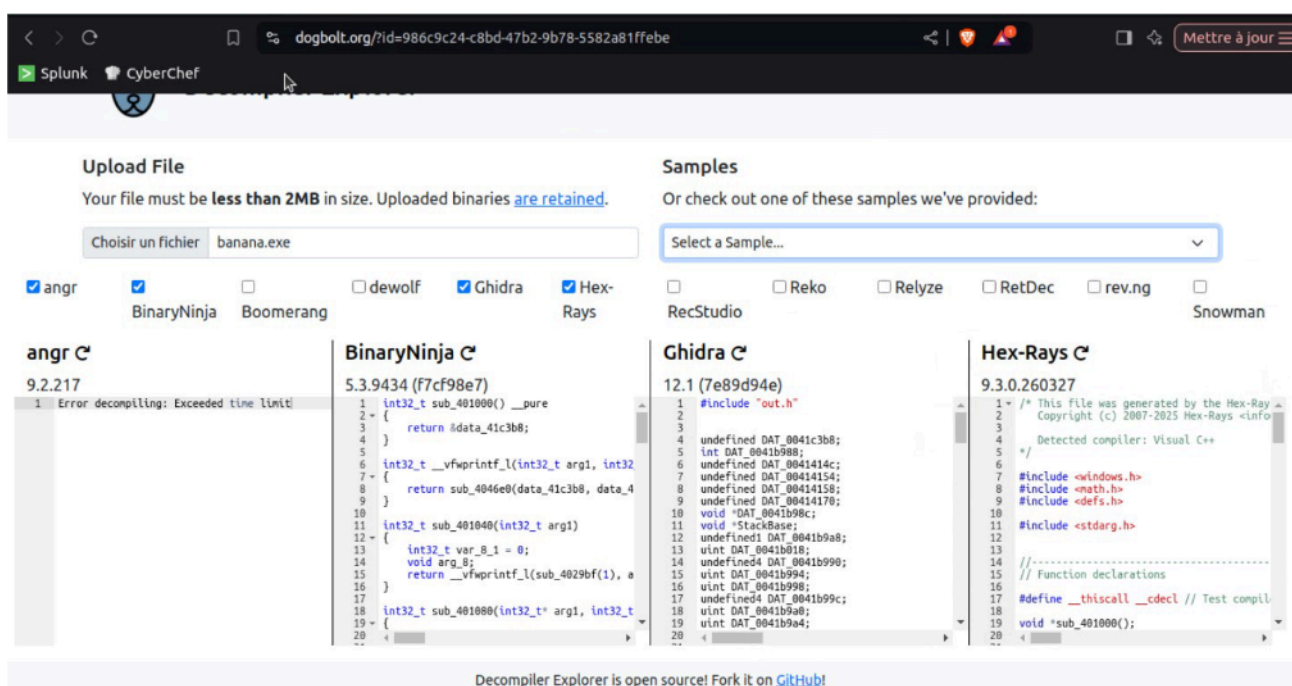
Values:
REG_SZ VMware User Process : (S) "C:\Program Files\VMware\VMware Tools\vmtoolsd.exe" -n vmusr
REG_SZ iambad : (S) C:\Users\boulet\AppData\Local\Temp\ssms.exeAccess.exe\xb0\xb5Wt\x4eyw\xfb\xcb\x5b\xdb\xbb!\xacrr
\xbb\xc4rPms\xcb2r\xa7\xfb8r \xf79\xa0\xe0r\xe8oqr\xa0js\xb0tr,\xf69\xff
\xfb9\xcdM-w.\xe5\xf5\xfe\xff\xff\xffT\x4eyw\xb2\xe1yw\xdb\xbb!\xff\
xc0\xc1\xc4r \xf69
```

banana.exe est le même fichier mais renommé de RemoteAccess.exe : preuve avec les SHA sum :

```
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 filescan | grep -l "banana.exe"
Volatility Foundation Volatility Framework 2.6
0x000000007d5144e0 16 0 RW-rwd \Device\HarddiskVolume2\Users\boulet\AppData\Local\Temp\banana.exe
0x000000007f87da70 16 0 RWD--- \Device\HarddiskVolume2\Users\boulet\AppData\Local\Temp\banana.exe
0x000000007f95b880 16 0 RW-rwd \Device\HarddiskVolume2\Users\boulet\AppData\Local\Temp\banana.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# volatility -f TP1-v2-Mem.raw --profile=Win7SP1x64 dumpfiles -Q 0x000000007f87da70 -D .
Volatility Foundation Volatility Framework 2.6
DataSectionObject 0x7f87da70 None \Device\HarddiskVolume2\Users\boulet\AppData\Local\Temp\banana.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# ls -l
total 2536688
-rw-r--r-- 1 root root 110592 juil 2 18:18 file.None.0xffffffffa8001a72d40.dat
-rw-r--r-- 1 root root 2359296 juil 1 09:57 file.None.0xffffffffa80030e4e00.vacb
-rw-r--r-- 1 root root 110080 juil 2 17:24 file.None.0xffffffffa8003742a10.img
-rw-r--r-- 1 root root 1310720 juil 1 10:00 file.None.0xffffffffa8003e45e00.vacb
-rw-r--r-- 1 root root 110080 juil 1 11:59 file.None.0xffffffffa80048e8590.img
-rw-r--r-- 1 root root 66244174 juil 1 11:10 mft_analyse.txt
-rw-r--r-- 1 root root 32768 juil 1 10:01 places.sqlite
-rw-r--r-- 1 root root 110592 juil 2 17:24 RemoteAccess_Bureau.exe
-rw-r--r-- 1 root root 110592 juil 1 11:59 RemoteAccess.exe
-rw-r--r-- 1 root root 73728 juil 1 10:33 ssms.exe
-rw-r--r-- 1 root root 327539777 janv. 26 2023 TP1-v2-Mem.7z
-rw-r--r-- 1 root root 2147483648 mai 12 2018 TP1-v2-Mem.raw
-rwxr-xr-x 1 forensics forensics 52168925 juil 10 2017 TP2-Mem.raw.7z
-rw-r--r-- 1 root root 1048576 juil 1 09:57 wal-16.dat
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# mv file.None.0xffffffffa8001a72d40.dat banana.exe

root@forensics-vm:/home/forensics/Cases/2_MEM/TP# sha256sum RemoteAccess_Bureau.exe
61cef013a2099e25b2706bfd1cddb6cc04d88241289501f6f95b89aade7f6473 RemoteAccess_Bureau.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP# sha256sum banana.exe
61cef013a2099e25b2706bfd1cddb6cc04d88241289501f6f95b89aade7f6473 banana.exe
root@forensics-vm:/home/forensics/Cases/2_MEM/TP#
```

Ghidra ne voulant pas fonctionner sur Linux, nous passons par dogbolt.org et obtenons le code décompilé suivant :



L'analyse du code source décompilé de RemoteAccess.exe fournit la preuve irréfutable de sa logique malveillante directement au sein de sa fonction main. Tout d'abord, le programme met en place une barrière défensive contre l'analyse dynamique via l'instruction `if ( IsDebuggerPresent() )`. Si un environnement de débogage est détecté, le malware bifurque pour appeler la fonction `sub_401040((int)aCheater)` afin d'afficher le message "Cheater !" avant de provoquer un plantage volontaire par l'instruction `_loaddll((char *)1)`.

Une fois cette vérification validée, le binaire initie sa routine furtive en récupérant son propre chemin d'accès et celui du dossier temporaire de Windows grâce aux API `GetModuleFileNameW` et `GetTempPathW`. Il emploie ensuite `CopyFileW(Filename, NewFileName, 0)` pour se dupliquer

discrètement sous l'alias `banana.exe` contenu dans la variable chiffrée `Source`. Immédiatement après, la fonction de téléchargement `sub_413640` prend le relais en utilisant les API réseau natives `InternetOpenUrlA` et `InternetReadFile` pour récupérer la seconde charge utile hébergée à l'adresse IP de l'attaquant `5.196.180.55`. Ce nouveau binaire malveillant, nommé `ssms.exe`, est écrit sur le disque puis exécuté silencieusement en arrière-plan par l'appel à la fonction `CreateProcessA(NULL, CommandLine, ...)`.

Pour garantir sa survie, le malware cible la ruche système globale en ouvrant la clé de registre de démarrage via `RegOpenKeyExW(HKEY_LOCAL_MACHINE, SubKey, ...)` où la variable `SubKey` pointe vers le chemin d'auto-exécution `Windows\CurrentVersion\Run`. La fonction `RegSetValueExA` y inscrit définitivement le chemin d'accès de `ssms.exe` pour qu'il se lance automatiquement à chaque démarrage du système. Enfin, le binaire initial se coupe brusquement par un `return 0`, s'effaçant ainsi de la table des processus actifs. Cette manœuvre de dissimulation explique et valide parfaitement les résultats forensic obtenus sur la RAM, où seul le processus enfant persistant `ssms.exe` (PID 2972) et sa clé de Registre système associée demeuraient visibles.

Vous pouvez vous basez sur les étapes suivantes à titre indicatif (pas forcément dans l'ordre):

- Récupérer la liste des mots de passe et tentez de casser le hash. → FAIT
- Déterminer le nom du PC et de l'utilisateur connecté. → FAIT
- Analyser la liste des processus. → FAIT
- Analyser l'historique des shells (linux)/cmd (windows). → FAIT
- Si vous identifiez un processus suspect, extrayez le et analysez le avec la commande `strings`.
- Si vous identifiez un exécutable suspect, extrayez le et analysez le avec la commande `strings`. → FAIT
- Analyser l'activité réseau. → FAIT
- Analyser les fenêtres ouvertes par l'utilisateur au moment du dump mémoire. → FAIT (MARWA LOUD)
- Analyser le système de fichier depuis le dump mémoire.
- S'il y a un support de stockage externe, analyser le avec `usbstor`.
- Pour valider l'enchainement chronologique de l'attaque, utilisez le plugin `timeliner`.
- Récupérer la MFT et extrayez les information en se basant sur les processus et exécutables identifiés.

3. Disque

Entreprise

M57.biz est une start-up développant un catalogue de "body-art"

Employés:

- Alison Smith-PDG (CEO)
- Jean-Directrice des finances (CFO)
- Bob, Carole, David, Emmy -Développeurs
- Gina, Harris-Marketing
- Indy -Business Development

Fonctionnement

m57.biz est une entreprise virtuelle

Développeurs:

- Les développeurs travaillent à la maison
- Journalièrement: Chat entre les employés
- Hebdomadairement: Réunion dans un bureau

Marketing&BusinessDev:

- Hotels ou Starbucks (toujours en déplacement)
- Réunion en personne toutes les deux semaines

La plupart des documents sont échangés par email

Situation

vol de données sensibles/exfiltration de document:

- Un tableur Excel contenant des informations confidentielles a été posté sur le forum web d'une entreprise concurrente
- Le tableur venait de l'ordinateur de la directrice financière (Jean)
- Vous disposez d'une copie du fichier "m57biz.xls"

Vous devez déterminer:

- Comment les informations confidentielles se sont retrouvées sur le site d'un concurrent?

Interviews

Jean (Directeur financier) :

- Alison m'a demandé de préparer le tableau pour une levée de fonds.
- Alison m'a demandé de lui envoyer par email.
- C'est tout ce que je sais.

Alison (PDG) :

- Je ne sais pas de quoi Jean parle.
- Je n'ai jamais demandé le document exfiltré à Jean.
- Je n'ai jamais reçu ce document dans ma boîte mail.

Éléments d'enquête

Login/Mots de passe :

- alison@m57.biz / mot de passe : ab=8989
- jean@m57.biz / mot de passe : gick*1212

Preuves (déjà prélevées et enregistrées) :

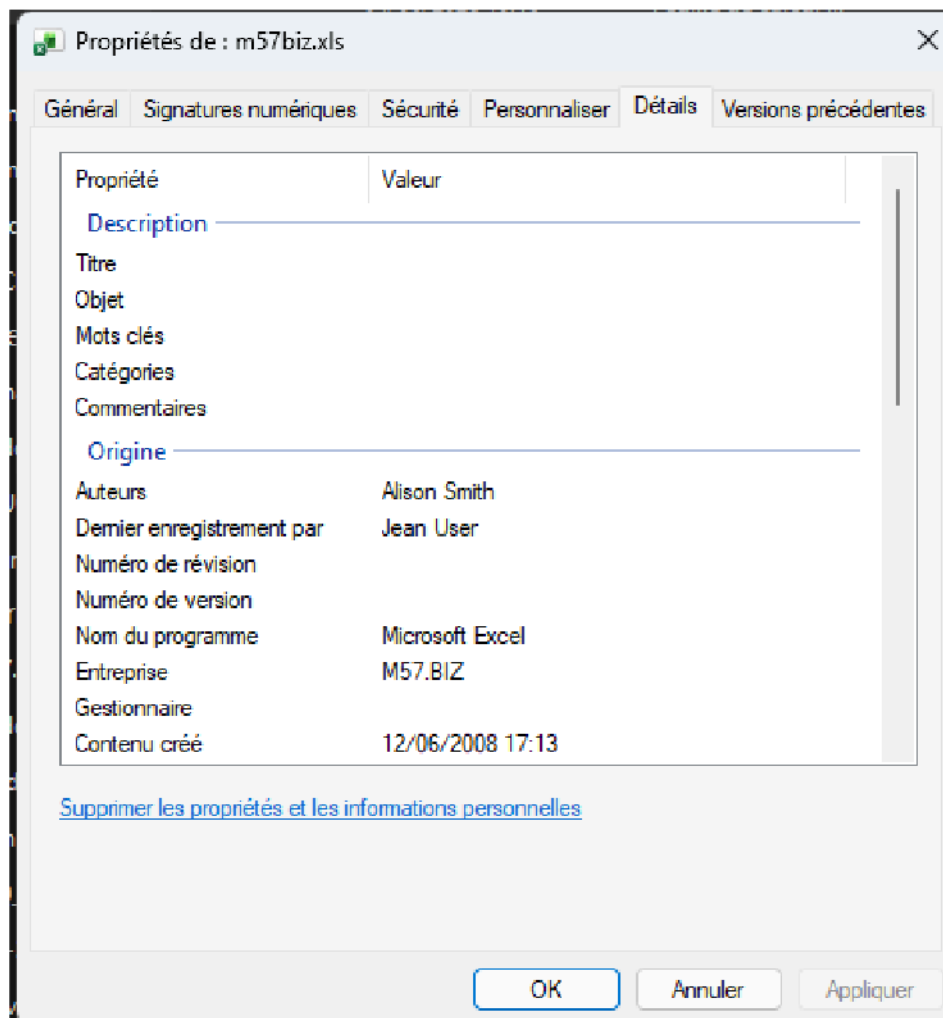
- Copie du disque de Jean
- Copie du tableau

Objectifs

Le client veut savoir :

- Quand a été créé le tableau ?

Le tableau a été créé le 12 juin 2008 :



- Comment est-il arrivé sur le site web d'un concurrent ?

Nous allons essayer d'analyser le disque de Jean avec Autopsy :

localhost:9999/autopsy?mod=0&view=1

Splunk CyberChef

CREATE A NEW CASE

1. **Case Name:** The name of this investigation. It can contain only letters, numbers, and symbols.
Jean

2. **Description:** An optional, one line description of this case.
Jean

3. **Investigator Names:** The optional names (with no spaces) of the investigators for this case.

a. Jean	b. Jean
c.	d.
e.	f.
g.	h.
i.	j.

NEW CASE CANCEL HELP

Dans son disque, nous retrouvons bien le fichier :

DEL	Type dir / in	NAME
	d / d	C:/Documents and Settings/Jean/Application Data/acccore/caches/users/m57jean
	r / r	C:/Documents and Settings/Jean/Application Data/Microsoft/Office/Recent/m57biz.LNK
	r / r	C:/Documents and Settings/Jean/Desktop/m57biz.xls
	d / d	C:/Documents and Settings/Jean/Local Settings/Application Data/AOL OCP/AIM/Storage/data/m57jean
	r / r	C:/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/20S83G5U/dref=http%253A%252F%252Fwww.aim.com%252Fredirects%252Finclient%252FAIM_UAC_v2[1].adp%253Fmagic%2

Nous allons essayer d'ouvrir le fichier alison57m.html :

d / d	C:/Documents and Settings/Jean/My Documents/AIMLogger/m57jean
r / r	C:/Documents and Settings/Jean/My Documents/AIMLogger/m57jean/IM Logs/alisonm57.html
r / r	C:/Documents and Settings/Jean/Recent/m57biz.lnk
r / r	C:/Program Files/Tencent/00_Games/00_Bubble Arena/object/mapElem/mine/ele57_stand.img

En lançant le fichier HTML dans le navigateur, nous obtenons :

icon IM History with buddy [alisonm57](#)

Friday, July 18, 2008

alisonm57 (6:05:38 AM): You know,
alisonm57 (6:05:48 AM): We really should spend more time working and less time chatting about current events.
m57jean (6:05:49 AM): thanks for asking. I did, but I'm not sure what to do with them.
alisonm57 (6:05:58 AM): How many times have we changed what we are doing with this company?
alisonm57 (6:06:05 AM): Did you catch that guy over there?
alisonm57 (6:06:18 AM): DA9AE15D-A73B-4576-B275-F6AB18139EB2-326-0000014A17858218.png
alisonm57 (6:06:21 AM): You are G2G?
alisonm57 (6:06:28 AM): 8EF2F170-CAC5-48FE-9182-61201B8E1F8B-326-0000014CD12A4382.png
alisonm57 (6:06:35 AM): Why aren't these people working for us?
alisonm57 (6:06:44 AM): A8872E59-0B28-4520-95F9-C6879D0AB3AC-326-000001506784F801.png
alisonm57 (6:06:57 AM): D0C2F746-7D52-4E52-A0A7-5E79286A7937-326-0000015381ED65C3.png
alisonm57 (6:07:00 AM): Hello?
m57jean (6:07:03 AM): um... I wasn't paying attention. bad case of PMS today. sorry.
alisonm57 (6:07:10 AM): Are you there, or are you choking on your latte again?
alisonm57 (6:07:14 AM): 34D16849-C794-42FB-85B8-078C19783C3B-326-000001575EE225E2.png
m57jean (6:07:15 AM): *snork*
alisonm57 (6:07:18 AM): 22ACC036-F67C-4CE2-8227-2F48B44FD094-326-0000015885193788.png
alisonm57 (6:07:25 AM): Get with the program, java girl.
alisonm57 (6:07:32 AM): 6B7CDE4B-C017-49E9-B628-FA0E7705DCD8-326-0000015B96EBF613.png
alisonm57 (6:07:41 AM): 751ADFD1-6F48-4FDA-925C-23E3D9977C61-326-0000015DD0BE39CF.png
alisonm57 (6:07:46 AM): 1A2BF0EA-C4A1-4058-9D37-726CD81F6649-326-0000015EEFCBEAF0.png
m57jean (6:07:50 AM): I'm really busy looking for a new laptop bag. Do you how much those cost?
alisonm57 (6:08:01 AM): Are you gonna charge it to the company?

alisonm57 (6:08:01 AM): Are you gonna charge it to the company?
alisonm57 (6:08:07 AM): 4BF198EB-924E-4D85-B385-4C09F0CBB962-326-00000163DF6B6B51.png
m57jean (6:08:16 AM): They've been complaining about 2Q issues.
m57jean (6:08:21 AM): might not be a good time.
alisonm57 (6:08:34 AM): Is [Amanda Bynes](#) really going out with 'Family' guy Seth McFarlane
alisonm57 (6:08:51 AM): Apparently she is... <http://news.aol.com/entertainment/television/article/is-bynes-ireallyi-going-out-with-him/85999>
m57jean (6:08:52 AM): I don't know. I'm here all the time. no time for TV.
alisonm57 (6:09:07 AM): 63AFA29E-B920-4150-B280-80E727543135-326-00000171DF536DB9.png
alisonm57 (6:09:13 AM): Def dating.
m57jean (6:09:20 AM): she's cute though. he's nasty.
alisonm57 (6:09:24 AM): How much cash is left in the account?
m57jean (6:09:43 AM): mmm.... I think we have about \$5K discretionary.
m57jean (6:10:11 AM): I think the boss has been dipping.
m57jean (6:10:28 AM): but he dips his everything in everything. yk?
alisonm57 (6:10:41 AM): Uh, Jean, I am the boss. Remember?
alisonm57 (6:10:51 AM): You work for me.
m57jean (6:10:54 AM): sorry. told you the hormones were bad.
m57jean (6:11:05 AM): must be that second job I moonlight at... ha ha.
alisonm57 (6:11:10 AM): That's not going to work, when you are working for me.
m57jean (6:11:23 AM): Yes MA'AM.
alisonm57 (6:12:10 AM): let's fine some more skin in the office. I really do not think that web-based tattoo removal with the USB laser tele-operated by some doctor in Pune is going to be a good launch product.
alisonm57 (6:12:13 AM): But you never know.
m57jean (6:12:23 AM): it depends on how we market it.
m57jean (6:12:45 AM): what do you think the percentage of people in the US would be who want their tats off in 5 years?
alisonm57 (6:12:54 AM): we're hoping it will be high.
alisonm57 (6:13:12 AM): l8tr
m57jean (6:13:13 AM): I'm thinking there are sooooo many people who will regret it. and I think they'll be the younger ones actually.

m57jean (6:13:13 AM): I'm thinking there are sooooo many people who will regret it. and I think they'll be the younger ones actually.
m57jean (6:13:19 AM): ttn.
Monday, July 21, 2008
m57jean (12:50:12 AM): hey, did you just message me?
alisonm57 (12:50:36 AM): I did.
alisonm57 (12:50:41 AM): Did you get it?
m57jean (12:51:54 AM): yep. just replied.
alisonm57 (12:53:06 AM): Okay. THanks.
alisonm57 (12:53:09 AM): I'll check it out.
m57jean (12:53:25 AM): not unless you're feeling trivial.
alisonm57 (12:53:44 AM): What?
m57jean (12:54:03 AM): check out whatever I was babbling about on email. don't worry about it.
m57jean (12:54:13 AM): hi-speed a must?
m57jean (12:54:17 AM): for your next hotel.
alisonm57 (12:54:17 AM): Okay. Let me chec in with you later.
alisonm57 (12:54:33 AM): I like special hotels, you know. Ones with a lot of extras.
m57jean (12:54:43 AM): yeah. checking in on it.
alisonm57 (12:54:49 AM): THanks.
m57jean (12:55:17 AM): going to use notebook app to put together itinerary
alisonm57 (1:46:15 AM): Jean?
alisonm57 (1:46:30 AM): Are you g2g?
m57jean (1:46:45 AM): yeah. I'm here. g where?

Nous trouvons ces lignes qui sont intéressantes :

alisonm57 (6:09:24 AM): How much cash is left in the account?
m57jean (6:09:43 AM): mmm.... I think we have about \$5K discretionary.
m57jean (6:10:11 AM): I think the boss has been dipping.
m57jean (6:10:28 AM): but he dips his everything in everything, yk?
alisonm57 (6:10:41 AM): Uh, Jean, I am the boss. Remember?
alisonm57 (6:10:51 AM): You work for me.
m57jean (6:10:54 AM): sorry. told you the hormones were bad.
m57jean (6:11:05 AM): must be that second job I moonlight at... ha ha.
alisonm57 (6:11:10 AM): That's not going to work, when you are working for me.
m57jean (6:11:23 AM): Yes MA'AM.

En gros, Jean crache sur son boss avec qui il discute.

Donc Jean a envoyé le fichier à un pirate et la vraie Alison est hors de cause même si elle a subi du phishing.

- Qui est impliqué ?

L'analyse de l'historique des conversations AIM entre le compte suspect alisonm57 et la directrice financière Jean (m57jean) permet de reconstituer avec certitude le scénario de l'exfiltration de données. Les journaux de chat du vendredi 18 juillet démontrent une manœuvre flagrante d'usurpation d'identité. Lors d'un échange informel, Jean commet l'erreur de critiquer son patron en déclarant *"I think the boss has been dipping"*, ce qui contraint l'attaquant à la recadrer instantanément par la phrase *"Uh, Jean, I am the boss. Remember? You work for me"* afin de maintenir son imposture et de réaffirmer son autorité hiérarchique.

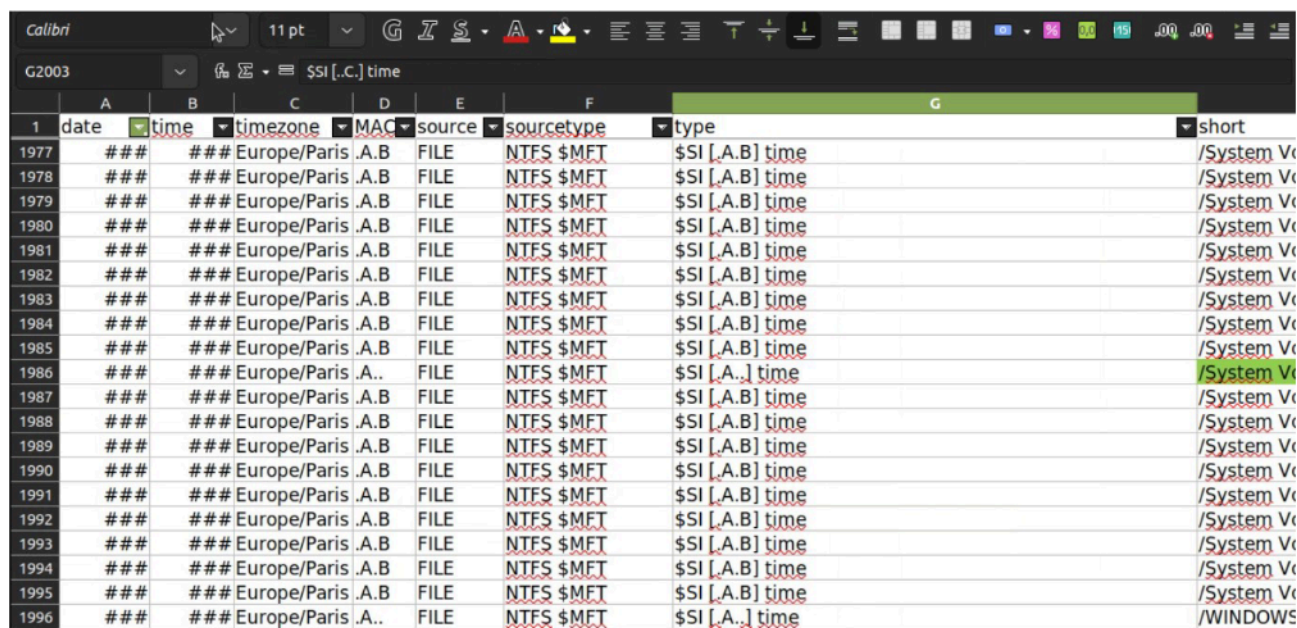
La compromission finale et l'envoi du document se matérialisent le lundi 21 juillet. L'attaquant utilise une technique d'ingénierie sociale multicanal : il transmet d'abord une demande par e-mail, puis interpelle Jean sur la messagerie instantanée en lui demandant *"Did you get it?"*. Pensant

obéir de bonne foi à sa directrice générale, Jean confirme l'envoi de la pièce jointe confidentielle en répondant "yep, just replied. check out whatever I was babbling about on email". Ce dialogue prouve que le tableau Excel n'a pas été volé via un malware ou un piratage technique du disque, mais exfiltré par le biais d'une attaque de cyber-harponnage (Spear-Phishing). Jean est une victime crédule ayant succombé à une usurpation d'identité, la vraie PDG Alison est totalement hors de cause, et l'attaquant externe a récupéré le fichier par messagerie avant de le publier chez le concurrent.

log2timeline

Analyser le disque dur TP2-HDD.E01/E02 et identifier les éléments de preuves. Pour bien valider la chronologie des éléments de preuves, des outils comme Plaso permettent de faciliter l'hordatage. La commande log2timeline a été utilisée pour généré un timeline du disque dur, vous pouvez le récupérer dans le fichier M57-Jean-20-July-filtered.zip. Analysez le et retracer un timeline des activités que vous avez pu identifier.

Nous pouvons d'abord ouvrir la timeline dans Calc :



1	A	B	C	D	E	F	G	
	date	time	timezone	MAC	source	sourcetype	type	short
1977	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1978	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1979	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1980	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1981	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1982	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1983	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1984	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1985	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1986	###	###	Europe/Paris	.A..	FILE	NTFS \$MFT	\$SI [.A.] time	/System Vc
1987	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1988	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1989	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1990	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1991	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1992	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1993	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1994	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1995	###	###	Europe/Paris	.A.B	FILE	NTFS \$MFT	\$SI [.A.B] time	/System Vc
1996	###	###	Europe/Paris	.A..	FILE	NTFS \$MFT	\$SI [.A.] time	/WINDOWS

C'est complètement illisible.

La légende est :

Calibri	11 pt	G	I	S	A						
A4		f	Σ			EXECUTION					
	A	B	C	D	E	F					
1	FILE OPENING										
2	WEB HISTORY										
3	DELETED DATA										
4	EXECUTION										
5	DEVICE or USB USAGE										
6	FOLDER OPENING										
7	LOG FILE										
8											

Nous pouvons filtrer uniquement sur m57 :

1	short	desc
2141	/Documents and Settings/Jean/My Documents/AIMLogger/m57jean/IMLOGS~1	/Documents and Settings/Jean/My Documents/AIMLogger/m57jean/IMLOGS~1
2142	/Documents and Settings/Jean/My Documents/AIMLogger/m57jean/IMLOGS~1/AIM~1.HTM	/Documents and Settings/Jean/My Documents/AIMLogger/m57jean/IMLOGS~1/AIM~1.HTM
2075	Software/Microsoft/ProtectedStorageSystemProvider/S-1-5-21-484763869-796845957-839522115	Key name: HKEY_USER/Software/Microsoft/ProtectedStorageSystemProvider/S-1-5-21-484763869-796845957-839522115
4007	visited http://www.qqgames.com/cgi-bin/Adpush?sn=m57jean&2=10010210&-1=20010233&36	URL:http://www.qqgames.com/cgi-bin/Adpush?sn=m57jean&2=10010210&-1=20010233&36
4008	/Documents and Settings/Jean/My Documents/AIMLogger/m57jean/IMLOGS~1/AIM~1.HTM	/Documents and Settings/Jean/My Documents/AIMLogger/m57jean/IMLOGS~1/AIM~1.HTM
4038	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/6H696DSF/m57jean	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/6H696DSF/m57jean
4041	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/6H696DSF/m57jean	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/6H696DSF/m57jean
4042	visited http://sync.aol.com/m57jean	URL:http://sync.aol.com/m57jean
4043	Software/AmericaOnline/AM6/Users/m57jean	Key name: HKEY_USER/Software/AmericaOnline/AM6/Users/m57jean
4072	visited http://servedby.advertising.com/site=743164/size=120090/u=1/bnum=27073488/xsxd	URL:http://servedby.advertising.com/site=743164/size=120090/u=1/bnum=27073488/xsxd
4073	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre
4084	visited http://servedby.advertising.com/site=743164/size=120090/u=1/bnum=34254022/xsxd	URL:http://servedby.advertising.com/site=743164/size=120090/u=1/bnum=34254022/xsxd
4085	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/GN0FIJ4N/dref	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/GN0FIJ4N/dref
4086	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/GN0FIJ4N/dref	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/GN0FIJ4N/dref
4091	visited http://servedby.advertising.com/site=743164/size=120090/u=1/bnum=75569647/xsxd	URL:http://servedby.advertising.com/site=743164/size=120090/u=1/bnum=75569647/xsxd
4096	visited http://r1.beta.ace.advertising.com/site=743164/size=120090/u=1/bnum=81406570/xsxd	URL:http://r1.beta.ace.advertising.com/site=743164/size=120090/u=1/bnum=81406570/xsxd
4099	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre
4119	visited http://servedby.advertising.com/site=743164/size=120090/u=1/bnum=68047781/xsxd	URL:http://servedby.advertising.com/site=743164/size=120090/u=1/bnum=68047781/xsxd
4121	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre

Nous pouvons voir l'ouverture du fichier m57biz.xls depuis Internet Explorer probablement pour envoyer un mail :

1	source	type	short
4010	NTFS \$MFT	\$SI [MACB] time	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre
4024	Internet Explorer	Client Last Accessed	visited http://r1.beta.ace.advertising.com/site=743164/size=120090/u=1/bnum=16645187/xsxd
4025	NTFS \$MFT	\$SI [MACB] time	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre
4981	Internet Explorer	Last Access	visited file:///C:/Documents%20and%20Settings/Jean/Desktop/m57biz.xls

O4981		Not the default browser ()
	J	
1	short	desc
4010	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre/	
4024	visited http://r1.beta.ace.advertising.com/site=743164/size=120090/u=1/bnum=16645187/xsxd URL:http://r1.beta.ace.advertising.c	
4025	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre/	
4981	visited file:///C:/Documents%20and%20Settings/Jean/Desktop/m57biz.xls URL:file:///C:/Documents%20and%20Settings/Jean/Desktop/m57biz.xls	

1	desc	version	filename
4010	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre	2	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre
4024	URL:http://r1.beta.ace.advertising.com/site=743164/size=120090/u=1/bnum=16645187/xsxd	2	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre
4025	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre	2	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre
4981	URL:file:///C:/Documents%20and%20Settings/Jean/Desktop/m57biz.xls	2	/Documents and Settings/Jean/Local Settings/Temporary Internet Files/Content.IE5/2PG1QL0D/dre

	N	O	P
1	inode	notes	format
4818	32724		Log2t::input::m
4824	16162	Not the default system browser (EXPLORE.EXE ("C:\Program Files\Mozilla Firefox 3 Beta 5\firefox	Log2t::input::iel
4825	32720		Log2t::input::m
4981	26516	Not the default browser ()	Log2t::input::iel